

SCG Review - Gemini Enterprise for CX - 2026-09-30

Executive Summary

This is a standard-depth review of `_src/geminiCustomerExperienceGuidance.csv` (141 requirements, 12 categories, IDs 10 to 1410) as it stood on disk at 2026-09-30 11:52, six days after the 2026-09-24 audit fixes and their validation. Structural, directive, hygiene, NIST SP 800-53 Rev. 5, HIPAA, HITRUST format, OWASP, MITRE ATLAS, and reference-URL checks were run programmatically against the file; every row was read for rationale adequacy, directive strength, risk and cost calibration, and mapping fit; six vendor pages carrying the highest-impact factual claims were re-fetched and the claims confirmed. The result is **0 Blocker, 2 Major, 6 Minor, 7 Info**. The guide is publish-ready once the two Majors are resolved. The first Major is not a defect in any requirement: since the last commit, every row's Revision has been reset to 0 and four cells reworded, and none of the supporting documents, the prompt log, or DocGen records that change, so the file and its audit trail now disagree. The second is a calibration gap: tool-registration alerting (ID 1140) is a SHOULD at Medium risk while the guide elsewhere treats tool registration as the primary path by which an agent's reach silently widens. Every NIST control identifier and title matched the OSCAL catalog, every HIPAA section is real, all 104 reference URLs resolved, and the ATLAS and OWASP identifiers matched their published lists. HITRUST CSF v11 titles were not verified against the licensed catalog.

Inputs

Input	Value
File under review	<code>_src/geminiCustomerExperienceGuidance.csv</code> (248,847 bytes, modified 2026-09-30 11:52; last commit 3e6dcce dated 2026-09-24)
Product	Gemini Enterprise for CX (CX Agent Studio, Agent Assist, CX Insights, Commerce agents), Google Cloud
Authoritative roots	<code>docs.cloud.google.com/gemini-enterprise-cx</code> , <code>cloud.google.com/security/compliance</code> , <code>cloud.google.com/terms</code> , per <code>resources.md</code>
Review depth	standard (all URLs status-checked; six pages content-checked; framework identifiers verified mechanically)
Compliance overlay	HIPAA and HITRUST CSF v11 (the two most frequent segments after NIST), inferred from the Mappings column
Rows per category	General 9; Identity & Access Management 14; Agents & Agent Management 12; AI Models & Model Management 4; Tools & External Integrations 22; Deployment & Channel Security 13; Agent Assist & Human Agent Support 11; Conversation Analytics & Insights 14; Data Protection & Privacy 13; Network & Perimeter Security 10; Monitoring & Analytics 11; Compliance & Certification 8
Risk distribution	107 High, 32 Med, 2 Low
Cost distribution	74 Low, 66 Med, 1 High
Directives	97 MUST, 32 MUST NOT, 10 SHOULD, 2 SHOULD NOT

Counts

Severity	Count
Blocker	0
Major	2
Minor	6
Info	7

Findings

#	Severity	Row ID	Category	Finding	Recommendation
1	Major	all rows (process)	General	The working-tree CSV differs from the last commit on 129 fields with no record of the change: all 141 rows now carry Revision 0, where commit 3e6dcce holds 48 rows at 2, 77 at 1, and 16 at 0, and README.md, notes/SCG-remediation-2026-09-24.md, notes/SCG-validation-2026-09-24.md, and prompt-log.md all still describe the 48/77/16 distribution and a "recertification cycle" in which changed rows were incremented. Four text cells also changed ("the vendor's" to "Google's" in ID 10 Notes, ID 230 Rationale, ID 450 Notes, ID 980 Notes) and the rendered guidance markdown was regenerated. DocGen.json lastUpdated still reads 2026-09-24 and there is no 2026-09-30 prompt-log entry. Under validation check D6a an all-	Decide and record which state governs. If the reset to Revision 0 is intended (first release, never published), add a dated prompt-log entry stating the decision, update the README revision counts and the 2026-09-24 remediation and validation notes with a one-line addendum, set DocGen.json lastUpdated to 2026-09-30, and commit. If it was not intended, restore the Revision column from HEAD. Either way, commit the four wording changes and the regenerated markdown with a message that names them.

#	Severity	Row ID	Category	Finding	Recommendation
				zero Revision column is the correct state for a first-release guide, and DocGen records publish: false, so the CSV state is defensible; the defect is that the audit trail an assessor will read now contradicts the file.	
2	Major	1140	Monitoring & Analytics	Risk and directive are under-stated relative to the guide's own analysis. ID 1140 ("Alerts SHOULD be configured for tool registration and modification in CX Agent Studio and for changes to the tools assigned to agents.") is SHOULD at Risk Med, while the parallel alerting rows ID 1120 (security and application settings) and ID 1130 (conversation deletion) are MUST at Risk High. ID 1140's own Rationale states that tool changes "alter the deployment's effective authorization boundary without a deployment step or an approval gate in the product", ID 360 relies on this alerting to reconcile the tool inventory, and ID 490 records that a registered tool extends reach before it is	Raise ID 1140 to MUST and Risk High. Keep Cost Low, since the DATA_WRITE methods it names are already required to be logged by ID 1070.

#	Severity	Row ID	Category	Finding	Recommendation
				assigned. Tool registration is the agent-capability escalation path the guide is built around, so detective coverage of it belongs at the same level as the settings and deletion alerts.	
3	Minor	950	Data Protection & Privacy	Risk Low with a MUST directive (check K5). "The short-lived caches the product maintains MUST be documented in the data flow record supporting certification." The 2026-09-24 validation note records this as deliberate.	Either raise Risk to Med, on the basis that an incomplete data flow record is a certification finding in its own right (which the Rationale already argues), or keep Low and leave the recorded justification in place. Consistency with ID 1220 (data flow record, Risk High) favours Med.
4	Minor	10, 60, 390, 450, 530, 620, 680, 1260	multiple	Notes exceed 1,000 characters on eight rows (ID 680 at 1,433; ID 450 at 1,249; ID 620 at 1,224; ID 10 at 1,125; ID 390 at 1,099; ID 530 at 1,031; ID 1260 at 1,026; ID 60 at 1,002), against a guide-wide mean of 536. The skill asks that Notes stay brief and carry implementation guidance, exception paths, and caveats. Much of the length on IDs 390 and 450 is narrative about inconsistencies in Google's own documentation, which belongs in notes/external-source-log.md.	Trim each to the actionable guidance and the one caveat the implementer needs; move documentation-inconsistency narratives to the external source log. The 2026-09-24 decision to keep ID 450's long Notes stands if the owner prefers; this finding records the deviation, not a demand.

#	Severity	Row ID	Category	Finding	Recommendation
5	Minor	1320, 1350	Agent Assist & Human Agent Support	HIPAA mapping is inconsistent across the Pre-GA prohibition family. IDs 10, 20, 30, 40, 1270, 1290, and 1390 cite 164.308(a)(8) (Evaluation); IDs 1320 and 1350, the same control pattern applied to Agent Assist features, cite 164.308(b)(1) and 164.314(a) (business associate contracts) instead. Both bases are defensible, but a GRC mapper will treat the family as two control types.	Add 164.308(a)(8) (Evaluation) to IDs 1320 and 1350, or add the business associate citations to the other Pre-GA rows so the family maps uniformly.
6	Minor	1100	Monitoring & Analytics	HIPAA citation one level too shallow: 164.316(b)(2) (Time Limit). In 45 CFR 164.316, paragraph (b)(2) is "Implementation specifications" and the six-year time limit is paragraph (b)(2)(i). The Notes cite the correct paragraph.	Change the Mappings segment to 164.316(b)(2)(i) (Time Limit).
7	Minor	680	Agent Assist & Human Agent Support	Residency row carries no HIPAA segment, while the peer residency rows ID 870, ID 880, and ID 1360 cite 164.308(a)(1)(ii)(B) (Risk Management).	Add HIPAA: 164.308(a)(1)(ii)(B) (Risk Management) to ID 680 for consistency with the other residency rows.
8	Minor	1320	Agent Assist & Human Agent Support	HITRUST CSF v11 segment absent where the row's own HIPAA mapping places it in the third-party domain. ID 1320 cites 164.308(b)(1) and	Add HITRUST CSF v11: 05.k (Addressing Security in Third Party Agreements) or 06.d (Data Protection and Privacy of

#	Severity	Row ID	Category	Finding	Recommendation
				164.314(a) , for which the alignment matrix pairs 05.k ; its twin ID 1350 carries 06.d .	Covered Information) to ID 1320, matching whichever basis finding 5 settles on.
9	Info	20, 30, 40, 50, 70, 80, 90, 130, 170, 290, 1210, 1230, 1250, 1390, 1400	multiple	Sixteen cells refer to "this guide" (for example ID 20 Notes: "This prohibition is a specific application of this guide's baseline prohibition"; ID 170 Notes: "each carried by their own requirement in this guide"). No cell cites another row by ID and no cell references another SCG, so the standalone rule recorded on 2026-09-23 is met. Recorded so the owner can decide whether the phrase itself is acceptable in a row lifted into a control matrix.	No change required. If the phrase is unwanted, replace with the substantive statement (for example "the baseline prohibition on Pre-GA features").
10	Info	300, 1100	multiple	Both www.ecfr.gov references return HTTP 200 to a scripted fetch only after redirecting to the unblock.federalregister.gov bot check, as recorded on 2026-09-24. They are authoritative and were confirmed in a browser on 2026-09-24.	Keep as cited. Re-confirm in a browser before publication.
11	Info	10, 20, 180, 740, 800, 910, 930, 960, 1180, 1190, 1200, 1210, 1270, 1320, 1350, 1390, 1400	multiple	Two cloud.google.com reference paths now redirect to a different path on docs.cloud.google.com :	Leave as cited for this cycle; update to the canonical docs.cloud.google.com paths in the next update so the citations

#	Severity	Row ID	Category	Finding	Recommendation
				resource-manager/docs/organization-policy/restricting-service-accounts to organization-policy/restrict-service-accounts (ID 180), and security/compliance/hipaa to docs/security/compliance/hipaa (sixteen rows). All return 200.	survive retirement of the legacy host.
12	Info	25 rows	multiple	OWASP LLM Top 10 citations use the 2025 edition; OWASP published a 2026 edition on 2026-08-03 and the guide's 2026-09-24 remediation recorded the migration as an open workstream item. All ten 2025 titles cited match the genai.owasp.org list.	No change this cycle. Schedule the remap as recorded.
13	Info	categories	multiple	Category set differs in name from the generator catalog but not in coverage: the guide uses "Compliance & Certification" where the catalog names "Compliance & Attestation", and has no "Content Generation" or "Data Input & File Handling" heading, but the controls those categories hold are present (output controls in IDs 240, 260, 300, 310, 640, 650, 670; ingestion and file handling in IDs	No change required.

#	Severity	Row ID	Category	Finding	Recommendation
				390, 400, 1340, 1360, 1370, 1380).	
14	Info	114 rows	multiple	HITRUST CSF v11 is cited on 114 of 141 rows with 22 distinct references, all in dotted notation, all within categories 01 to 11, and every title matches the reviewer's curated table. Titles were not verified against the licensed v11 catalog, which has no public form.	Confirm the 22 references against the organization's licensed copy before publication, as the 2026-09-24 validation note already asks.
15	Info	20, 40, 50, 320, 740, 800, 1270, 1320, 1350, 1360, 1390	multiple	Eleven rows rest on a Preview, Pre-GA, allowlist, or unreleased status last verified on 2026-09-24. Launch stages change without a release note.	Re-verify each at the next release-note review and before publication; ID 1250 already requires the reassessment on a transition.

Coverage Analysis

Categories

Expected	Present	Notes
General	Yes (9)	Generic Pre-GA prohibition at ID 10 plus feature-specific rows; certification gate, release review, baseline, training.
Identity & Access Management	Yes (14)	Federation, MFA, role scoping, separation of duties, service agent least privilege, key prohibition, recertification, JIT, device posture.
Data Protection & Privacy	Yes (13)	CMEK at project creation, key availability and version retention, residency, logging region, retention, training restriction, DLP template location, deletion procedure, Access Approval.
Network & Perimeter Security	Yes (10)	VPC Service Controls perimeter, sequencing, dry run, allowed origins, Service Directory, in-perimeter resources, rule hygiene, cross-perimeter references, import and export, perimeter change control.
Monitoring & Analytics	Yes (11)	Data Access logs for both services, SIEM export, retention, log integrity,

Expected	Present	Notes
		alerts on settings, deletion, tools, read volume, dashboard dependency, incident response.
AI Models & Model Management (AI platform)	Yes (4)	Allowlist, Preview prohibition, sub-agent override, launch-stage verification.
Agents & Agent Management (AI platform)	Yes (12)	Guardrails, prompt guard, blocklist, secrets, review, evaluation, determinations, disclosure, generated agents, delegation chains, versioning.
Content Generation (AI platform)	Folded	Output controls sit under Agents (240, 260, 300, 310) and Agent Assist (640, 650, 670). See finding 13.
Data Input & File Handling (AI platform)	Folded	Data store, file search, ingestion, and RAG rows sit under Tools & External Integrations (390, 400, 1340 to 1380). See finding 13.
Product-specific additions	Yes	Tools & External Integrations (22), Deployment & Channel Security (13), Agent Assist & Human Agent Support (11), Conversation Analytics & Insights (14), Compliance & Certification (8). No category has fewer than four rows.

STRIDE Coverage (from infosec-architect/threat-modeling)

STRIDE	Addressed?	Row(s)	Notes
Spoofing	Yes	100, 110, 180, 200, 530, 540, 550, 1330	Federation and MFA for builders, per-member authentication for members, no service account keys, origin binding for the widget, client function results never establish identity.
Tampering	Yes	250, 270, 400, 410, 420, 450, 640, 1110	Prompt guard, ingestion review, untrusted tool output, MCP supply chain review, code review of Python tools, summary review, log integrity.
Repudiation	Yes	200, 1070, 1080, 1090, 1100, 1110, 1310	Data Access logs on both services, SIEM export, six-year retention, tamper protection, correlation identifier carried into backends.
Information Disclosure	Yes	380, 390, 460, 660, 720, 730, 790, 800, 920, 930	Backend object-level authorization, corpus scoping, client function arguments, DLP redaction on every path, Pub/Sub payload control, Sheets prohibition.
Denial of Service	Yes	520, 590, 850, 860, 1300	reCAPTCHA and origin checks, gateway throttling,

STRIDE	Addressed?	Row(s)	Notes
			key availability with 30-day loss fuse, key version retention, quota and cost alerting.
Elevation of Privilege	Yes	120, 130, 140, 160, 170, 330, 350, 380, 1390, 1400, 1410	Admin role scoping, basic role prohibition, separation of duties, client role inventory, service agent least privilege, delegation chains, project as trust domain, A2A and Owner-only channels prohibited.

Identity Governance Domains (from infosec-architect/identity-governance)

Domain	Addressed?	Row(s)	Notes
Identification	Yes, with recorded residual	350, 1230, 1240, 1310	The product offers one service agent per project rather than a per-agent identity; the guide states this as a residual risk (1230), bounds it by project (350), inventories agents (1240), and carries attribution across the tool boundary with a correlation identifier (1310).
Authentication	Yes	100, 110, 180, 200, 530, 540	Federation, MFA, workload identity in place of keys, per-member OAuth2 or custom authentication, self-hosted broker for public agents.
Authorization & Delegation	Yes	120 to 170, 330, 380, 410, 440, 1390, 1410	Least privilege on human and service principals, separation of duties on two role pairs, delegation chain reviewed as one surface, tool output cannot authorize actions. RFC 8693 token exchange is not offered by the product; the guide compensates with backend session-bound authorization (380).
Lifecycle	Yes	100, 190, 210, 490	Joiner-mover-leaver through federation, quarterly recertification, time-bound elevation, removal of unused tool registrations.
Auditability	Yes	1070 to 1130, 1150, 1310	Both services' Data Access logs, export, retention, integrity, alerts, anomaly detection, backend correlation.

Domain	Addressed?	Row(s)	Notes
Trust Boundaries	Yes	350, 560, 580, 970 to 1060, 1390, 1400	Project per trust domain, non-production separation, third-party channel assessment and BAA, perimeter, cross-perimeter references and A2A and Meta channels prohibited.

Defense in Depth, Least Privilege, Assume Breach, Auditability of Controls

Data exfiltration is controlled at four layers: the perimeter and allowed-origins policy (970 to 1030, 1000), identity (170, 380, 530), data (620, 720, 920 redaction; 390, 660 corpus scoping), and channel (510, 590, 790, 800). IAM rows start from named individuals and minimum grants with time-bound elevation (120, 170, 210) and prohibit the broad grants (130, 180). Post-compromise controls are present: log integrity outside project administrators' control (1110), deletion and read-volume alerting (1130, 1150), containment steps in an incident procedure (1170), version rollback (340), and blast-radius bounding by project (350). Changes to the controls themselves are alerted on: security and application settings (1120), perimeter changes (1060), sink and retention changes (1110). No gap found.

Authoritative-source Verification Log

Structural and hygiene checks (all rows)

Check	Result
Header matches scg-generator/templates/securityConfigGuidance.csv exactly (17 columns)	Pass
Every row parses to 17 fields (RFC 4180); 12 category rows with 16 empty trailing fields	Pass
IDs positive integers, unique, multiples of 10, ascending within each category; flat append-only numbering (1260 to 1410 sit in earlier categories by design)	Pass
Revision non-negative integer on every row (all 0; see finding 1)	Pass (D6a)
ID, Revision, Requirement, Rationale, Risk, Cost, References, Mappings populated on every row	Pass
Eight downstream columns empty on every row	Pass
Risk and Cost in {High, Med, Low}	Pass
Exactly one bolded RFC 2119 directive per Requirement; no lowercase must, should, or may; no directive markup in Rationale or Notes	Pass
Every Risk High row uses MUST or MUST NOT	Pass
No non-ASCII characters, no embedded line breaks, no leading or trailing whitespace	Pass
No cell cites another row by ID or another SCG	Pass (see finding 9)
Pre-GA prohibition present, generic, in General, Risk High (ID 10), plus feature-specific rows 20, 30, 40, 50, 740, 1270, 1320, 1350, 1390	Pass

Framework identifier checks

Framework	Result
NIST SP 800-53 Rev. 5	74 distinct controls and enhancements cited; every identifier and title matched the NIST OSCAL Rev. 5 catalog fetched 2026-09-30 (SC-7(5) uses an ASCII hyphen for the catalog's em dash, per the no-non-ASCII rule). Every enhancement appears with its parent on the same row. NIST 800-53 present on all 141 rows. Segment order HIPAA, NIST 800-53, HITRUST CSF v11, OWASP, then ATLAS or AI RMF on every row.
HIPAA	30 distinct citations on 116 rows, all in 164.xxx(. . .) form and all real Security Rule, Privacy Rule, or Breach Notification Rule paragraphs. One depth defect (finding 6); two consistency findings (5, 7).
HITRUST CSF v11	22 distinct references on 114 rows, all \d{2}\. [a-z]{1,2}, all within categories 01 to 11, all under the HITRUST CSF v11: label, all titles matching the reviewer's curated table. Not verified against the licensed catalog. One absence noted (finding 8).
OWASP	LLM Top 10 2025 on 25 rows (all ten titles match <code>genai.owasp.org</code>); API Top 10 2023 on 8 rows (API1, API2, API4, API6 titles correct); Top 10 for Agentic Applications 2026 on 14 rows (ASI01 to ASI07 and ASI09 titles match the published list; the OWASP page itself links only the PDF, so titles were confirmed from the December 2025 announcement coverage). Never the sole segment on a row.
MITRE ATLAS	AML.T0051.001 (Indirect prompt injection), AML.T0053 (AI Agent Tool Invocation), AML.T0054 (LLM Jailbreak), AML.T0110 (AI Agent Tool Poisoning) all matched the ATLAS dataset (<code>atlas-data/dist/ATLAS.yaml</code>) fetched 2026-09-30.
NIST AI RMF	Function-level citations (GOVERN, MAP, MEASURE, MANAGE) on 7 rows; ID 1240 additionally names GOVERN 1.6 in Notes, which exists in NIST AI 100-1.

Reference URLs

104 distinct URLs across 141 rows, hosts `docs.cloud.google.com` (385 citations), `cloud.google.com` (67), `www.ecfr.gov` (2), `nvlpubs.nist.gov` (1); all on the authoritative allowlist. All 104 returned HTTP 200 on 2026-09-30. Two `cloud.google.com` paths redirect to a changed path on `docs.cloud.google.com` (finding 11); the two eCFR URLs land on the federalregister bot check for scripted clients (finding 10). No URL carries credentials or sensitive query parameters.

Content spot-checks (standard depth)

Page	Rows	Claim checked	Result
IAM roles overview (docs.cloud.google.com/iam/docs/roles-overview)	130, 1400	Admin, Writer, Reader are current basic roles; Owner, Editor, Viewer are legacy basic roles; "thousands of permissions" and "do not grant basic roles unless there is no alternative" quotes	Confirmed verbatim.
IAM roles and permissions for ces	140, 160, 500, 530, 1000, 1410	roles/ces.client holds ces.sessions.* and ces.tools.execute; ces.apps.update held by App Editor and not by Agent or Tools Editor; ces.securitySettings.update held by Security Settings Editor; Tools Editor holds ces.tools.* and ces.sessions.*	Confirmed.
SecuritySettings REST resource (v1beta)	140, 1000, 1120	Resource holds only endpointControlPolicy; ENFORCEMENT_SCOPE_UNSPECIFIED is treated as VPCSC_ONLY; ALWAYS applies regardless of VPC-SC	Confirmed verbatim.
Agent Assist data redaction and retention	620, 630	Security settings bound per conversation profile; no settings means no redaction; default and maximum retention window 30 days	Confirmed verbatim.
CX Agent Studio conversation history	889, 890, 900, 950, 910, 960	Default retention one year, maximum two; logging toggle disables all long-term data except BigQuery; 30-minute session memcache and 1-hour TTS cache; content "never" used to train production models; controlled just-in-time Google access	Confirmed.
CX Agent Studio audit logging	150, 570, 1050, 1070, 1120, 1130, 1140	ExportApp ADMIN_READ; ImportApp, UpdateSecuritySettings, UpdateApp ADMIN_WRITE; CreateTool, UpdateTool, DeleteConversation, BatchDeleteConversations, RunSession, CreateDeployment, UpdateDeployment DATA_WRITE; long-running operations produce two entries	Confirmed.

Top-3 Risks

1. **The file and its audit trail disagree (finding 1).** Every row's Revision was reset to 0 and four cells reworded after the last commit, with no note, log entry, or DocGen update. A HITRUST assessor or change-advisory reader who opens the README and the CSV side by side will find them contradictory, which undermines every other claim of traceability the project makes. It is a one-hour fix, and it should precede any further edits so the next change lands on a recorded baseline.
2. **Tool registration is under-monitored (finding 2).** ID 1140 asks only that alerts SHOULD exist for the change the guide identifies as the way an agent's reach widens without a deployment. Three other rows (360, 490, 1310) assume that alerting exists. Raising it to MUST at High closes the gap at no cost, since the underlying log methods are already mandated by ID 1070.
3. **Eleven rows rest on a launch stage last checked six days ago (finding 15).** Preview, allowlist, and unreleased statuses on IDs 20, 40, 50, 320, 740, 800, 1270, 1320, 1350, 1360, and 1390 change without a release note. A stage that moved between 2026-09-24 and publication would leave a prohibition or a compensating control pointing at a condition that no longer holds.

Sign-off Checklist

- ☐ All Blocker findings resolved (none raised)
- ☐ Finding 1 resolved: Revision reset recorded or reverted, README and notes reconciled, DocGen updated, working tree committed
- ☐ Finding 2 resolved: ID 1140 raised to MUST and Risk High
- ☐ Minor findings 3 to 8 dispositioned
- ☒ Pre-GA / Preview prohibition present (ID 10, generic, Risk High)
- ☒ NIST 800-53 cited on every row; all 74 identifiers and titles verified against the OSCAL Rev. 5 catalog
- ☐ HITRUST CSF v11 references (22) confirmed against the organization's licensed catalog
- ☒ HIPAA cited where PHI applies (116 rows); one depth correction and two consistency alignments pending (findings 5, 6, 7)
- ☒ References resolve to authoritative sources (104 of 104 live on 2026-09-30)
- ☒ Defense-in-depth verified (exfiltration controlled at perimeter, identity, data, and channel layers)
- ☒ Identity-governance domains all addressed, with the agent-identity residual recorded at ID 1230
- ☐ Risk/Cost calibration consistent across similar rows (finding 2 open; finding 3 owner's call)
- ☐ Launch-stage rows re-verified before publication (finding 15)

Resolutions (2026-09-30)

Applied at the owner's direction the same day; detail in `notes/SCG-remediation-2026-09-30.md`, verification in `notes/SCG-validation-2026-09-30.md`.

#	Severity	Resolution
1	Major	Resolved by recording the decision: the Revision reset to 0 is the intended first-release state for an unpublished guide. README, DocGen.json, the 2026-09-24 remediation and validation notes (addenda), the diff map, and the prompt log were reconciled. The working tree remains uncommitted for the owner to commit.
2	Major	Resolved. ID 1140 raised to MUST and Risk High.
3	Minor	Resolved. ID 950 Risk raised to Med.

#	Severity	Resolution
4	Minor	Resolved. All eight Notes trimmed below 1,000 characters with substance retained; documentation-inconsistency narratives moved to the external source log.
5	Minor	Resolved. HIPAA 164.308(a)(8) added to IDs 1320 and 1350.
6	Minor	Resolved. ID 1100 cites 164.316(b)(2)(i).
7	Minor	Resolved. HIPAA 164.308(a)(1)(ii)(B) added to ID 680.
8	Minor	Resolved. HITRUST CSF v11 05.k added to ID 1320.
9	Info	No change; recorded.
10	Info	Open; confirm the eCFR pages in a browser before publication.
11	Info	Deferred to the next update cycle.
12	Info	Open workstream item, unchanged.
13	Info	No change.
14	Info	Open; confirm against the licensed HITRUST catalog before publication.
15	Info	Resolved for this date: all eleven launch stages re-verified on 2026-09-30 and unchanged; logged in <code>notes/external-source-log.md</code> .